

24-HOUR STUDENT CHALLENGE

Personalised Vulnerability Triage

Turn public cyber data into five actions a small organisation can understand and defend.

24 HOURS Build and demo	TOP 5 Ranked actions	2+ PROFILES Prove personalisation	PUBLIC DATA No paid feeds
-----------------------------------	--------------------------------	---	-------------------------------------

READ THIS FIRST

Start with the provided CSV and JSON files. Do not spend the event building feeds or cleaning the internet. You are judged on whether one organisation receives a short, relevant, explainable list. A thoughtful prototype over 200 records will beat a generic dashboard over 20,000.

The challenge

HOW MIGHT WE

Help a small organisation describe the technology it runs and turn free public vulnerability information into a ranked top five - so that a non-expert can see what matters, why it matters, and what to do next?

Your prototype must answer

1. What should I pay attention to? - a ranked top five, not a database.
2. Why is this relevant to this organisation? - in plain language, tied to evidence.
3. What should I do next? - one safe, practical action.

Audience: undergraduate teams with limited or no cybersecurity experience. The demo must run without paid data, paid software, or a live API dependency.

1. The problem and the user

Public sources publish thousands of vulnerability records, severity scores, exploitation signals and advisories. They are valuable, but they are written for everyone. A college, clinic or small manufacturer uses only a small subset of the affected products and rarely has a dedicated threat analyst.

The pain point: a limited IT team cannot quickly tell which records touch its own services. When every item looks urgent, important warnings are delayed, effort is spent on irrelevant products, and people eventually stop reading.

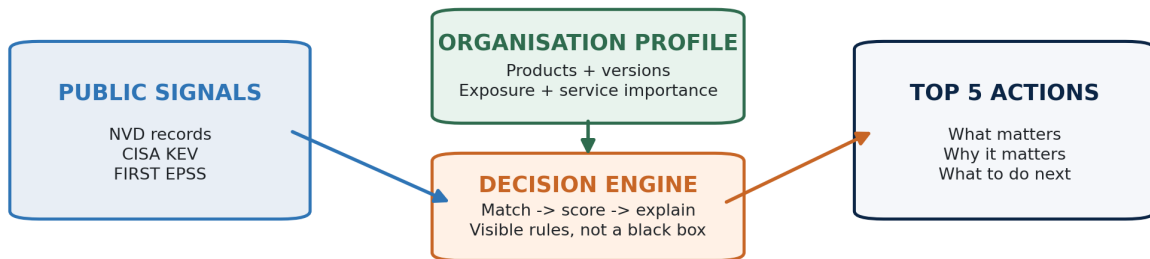


Figure 1. Organisational context converts a global feed into a short decision list.

What you will build

One working prototype with one job: load a fictional organisation profile and produce five vulnerability items that deserve attention, each with a visible reason, confidence level, source, and safe next step.

- **Input:** a provided profile describing technologies, exposure and service importance.
- **Decision:** match relevant products, prioritise with at least three visible signals, and handle uncertainty honestly.
- **Output:** a top five that a non-specialist can understand without your narration.

THE ANTI-SOLUTION

A global CVE table sorted only by CVSS is not personalised threat intelligence. Severity is one signal, not the answer.

2. Start from the data pack

At kick-off, every team receives a small, frozen starter pack. It removes ingestion and cleaning work so teams can begin with matching and decision logic.



Figure 2. The required 24-hour path. Live ingestion is intentionally outside the MVP.

Files provided

File	What it contains	Why it exists
vulnerabilities.csv	500-1,000 normalised CVE-product rows	NVD, CISA KEV and FIRST EPSS fields are already joined
profiles.json	Three fictional organisations plus a shared schema	Lets teams prove that outputs change by context
gold_set.csv	A small practitioner-ranked sample	Optional sanity check for your weights

Four terms you need

Term	Plain-language meaning
CVE	A public case number for one software vulnerability.
CVSS	Technical severity from 0 to 10. It does not know your organisation.
KEV	CISA's list of vulnerabilities confirmed as exploited in real attacks.
EPSS	An estimate of the probability that a CVE will be exploited in the next 30 days.

Public sources: [NIST NVD](#) | [CISA KEV](#) | [FIRST EPSS](#). Downloaded snapshots are recommended; live APIs earn no extra marks.

3. Personalise by matching the profile

The profile is the input that makes the result personal. For the 24-hour MVP, it needs only four kinds of context:

Profile field	Example	How it affects the result
Technology	apache / http_server / 2.4	Determines whether a vulnerability is a candidate
Exposure	internet-facing or internal	Raises or lowers urgency
Service	student portal	Lets the explanation name the organisation's own thing
Importance	critical, high, normal	Changes priority for the same technical flaw

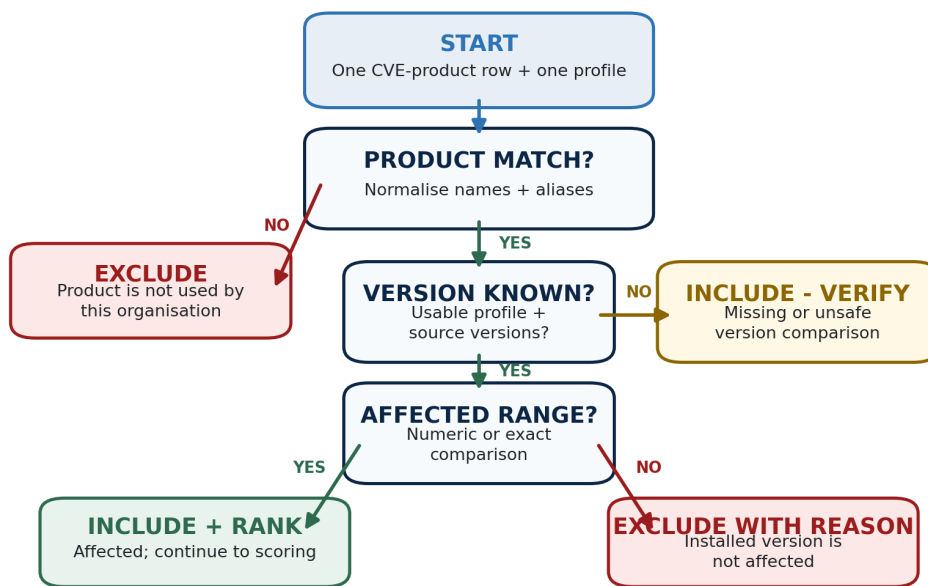


Figure 3. Matching has three honest outcomes: include, exclude, or include and verify.

Rules judges will check

- Normalise names and keep a small, documented alias table; Apache and apache must match.
- Compare clean numeric or exact versions when possible. You are not required to solve every vendor version format.
- If a version is missing or unsafe to compare, include the item as NEEDS VERIFICATION. Never guess and never silently drop it.
- The same engine must accept a second or unseen profile without hard-coded sector logic.

4. Rank with visible evidence

After matching, order the candidates. Use at least three signals and show how each one influenced priority. Rules, simple weights, statistics or another defensible method are all acceptable.

Signal	Source	Why it matters
Confirmed exploitation	CISA KEV	Strongest signal: someone is already using the vulnerability
Exploitation probability	FIRST EPSS	Forward-looking likelihood for items not yet in KEV
Internet exposure	Profile	An exposed service is easier for attackers to reach
Service importance	Profile	A critical service outranks a low-value test system
Technical severity	NVD CVSS	Useful context, but never sufficient on its own
Data confidence	Match quality	Unknown versions or incomplete records reduce certainty

WORKED EXAMPLE - ILLUSTRATIVE ONLY

KEV +40 | internet-facing +20 | critical service +15 | CVSS contribution +9 = 84 / URGENT. Choose your own logic, but display the contributing factors beside the result.

Required negative test

Show one vulnerability with CVSS 9.0 or higher that your system excludes or ranks low, and explain why. Valid reasons include: the product is not used, the installed version is outside the affected range, or the system is internal and low importance. This single test distinguishes personalisation from severity sorting.

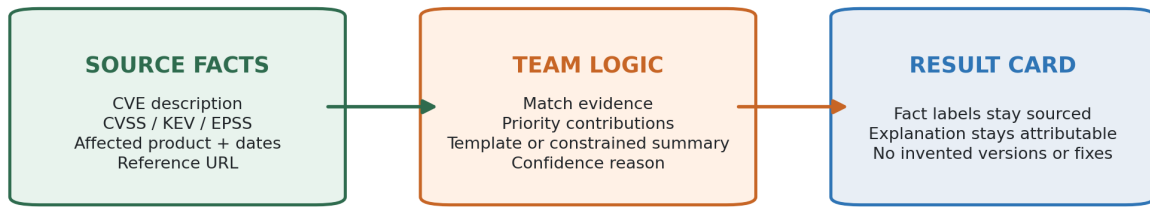
EXPLAINABLE OR IT DOES NOT COUNT

A score such as 87 / 100 without visible factors simply replaces one opaque number with another.

Bounded output

- Default to the top five. A way to view more is optional.
- Deduplicate by CVE and product before ranking.
- Show uncertainty as data, not as a hidden failure.

5. Explain the decision and preserve provenance



Every claim must be traceable back to the record used.

Figure 4. Facts, team logic and generated language must remain distinguishable.

Every top-five result must show

Element	What the user should see
Priority	Urgent, high, medium or low - plus visible contributing factors
Plain-language title	Consequence first; avoid unexplained jargon
Matched context	The organisation's product, service, exposure and importance
Why it matters	Evidence such as KEV, EPSS, CVSS and profile match
Potential impact	A cautious description supported by the record
Next step	One safe action: verify version, review vendor guidance, patch, restrict, monitor or escalate
Confidence	High, medium or low, with the reason
Traceability	Source name, publication/snapshot date and reference link

WHAT LOSES MARKS

Invented versions, dates, vendor names, exploitation claims or remediation steps. If an LLM phrases text, give it only record fields and retain a deterministic fallback.

Minimum demonstration

- Two profiles produce visibly different top-five lists.
- A judge can understand the top item and next step within 60 seconds without narration.
- One source claim is spot-checked successfully against the underlying row.
- The negative test is shown and defended.

6. A realistic 24-hour build plan

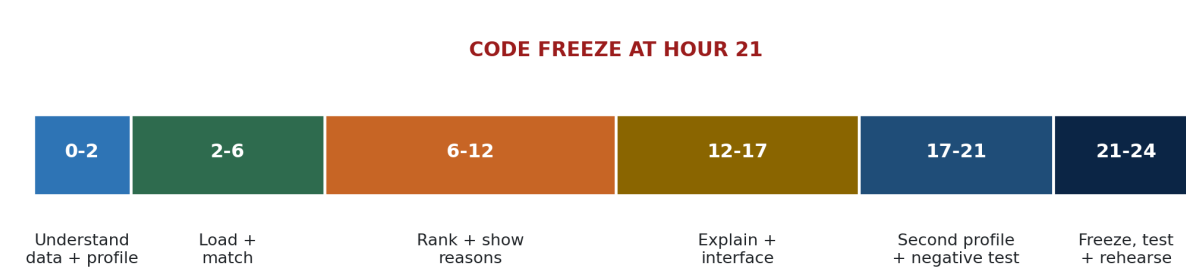


Figure 5. Reach a ranked terminal output by hour 12; polish only after the full path works.

Milestone gates

By	You should be able to demonstrate
Hour 2	Starter files load; one profile and ten sample rows are visible
Hour 6	A plain function returns matching CVE IDs for one profile
Hour 12	A terminal shows a top five with visible score reasons
Hour 17	Result cards show explanation, next step, confidence and source
Hour 20	A second profile and the negative test both work
Hour 21	Feature freeze; only defects, rehearsal and documentation remain

If you are behind

- Use the starter CSV; stop all live-data work.
- Keep the terminal or a minimal web page; do not build authentication, accounts or deployment.
- Use transparent rules instead of training a model.
- Support one result view and five items well.

Deliverables

- Working prototype that runs locally with cached or bundled data.
- Source code plus a README that starts the prototype in under five minutes.
- README sections describing sources, matching, ranking logic, assumptions and limitations.
- Three-minute presentation: problem, approach, live two-profile demo, negative test and limitation.

7. Scope, safety and ethics

IN SCOPE - build this	OUT OF SCOPE - do not spend time here
Provided CSV/JSON snapshots	Live ingestion pipelines or commercial feeds
Fictional organisation profiles	Real asset inventories or external reconnaissance
Vendor/product matching plus honest version handling	Universal CPE parsing or every vendor version format
Transparent rule or weighted ranking	Training, fine-tuning or opaque model scoring
One top-five decision view	Authentication, multi-tenancy, cloud deployment or alerting
Source-linked explanations and safe next steps	Exploit code, scanning, malware execution or offensive instructions

Conditions of entry

- Use only fictional, synthetic, public or organiser-provided organisational data.
- Do not scan, probe or test any system. Do not execute malware or include working exploit code.
- Do not collect or display personal information.
- Keep every automated summary linked to its source and visibly separate sourced facts from generated text.
- Recommendations are defensive only. The prototype may report what matched; it must never claim the organisation is secure.

LANGUAGE-MODEL POLICY

AI is optional and earns no automatic credit. The core demo must not depend on a paid API. If a model is used, provide a template-based or local fallback and do not allow it to add facts.

USE HONEST LANGUAGE

Say: 'Nothing matched this profile in the supplied data.' Never say: 'No critical issues' or 'You are secure.'

8. How the prototype will be judged

Category	Weight	What judges are looking for
Personalisation and matching	30%	Profile-driven results, correct exclusions and honest uncertainty
Explainability and next action	25%	Clear evidence, plain language and one safe step
Data integrity and provenance	15%	No invented facts; source, date and link remain visible
Usability	15%	A non-expert finds the top item and next step unaided
Technical completeness	10%	End-to-end local workflow is reliable
Creativity and impact	5%	A useful idea beyond the minimum, without weakening the core

Demo-time protocol

1. Load the organiser's unseen Profile D using the same schema as the development profiles.
2. Show that the top five changes and identify the profile fields that caused the difference.
3. Let a judge select one top item; the interface should explain why before the team does.
4. Trace one claim to the underlying starter-pack row and reference link.
5. Show the mandatory high-CVSS negative test and defend the lower ranking or exclusion.
6. State one known limitation and its effect on the output.

CORE JUDGING PRINCIPLE

The best solution is not the one that shows the most threat information. It is the one that converts public data into relevant, explainable and actionable intelligence for one specific organisation.

What earns no marks by itself

- More records, more feeds, a complex architecture, a hosted deployment or the use of AI.
- Visual polish that hides weak matching, unexplained ranking or unsupported claims.

Appendix A. Starter-pack schemas

vulnerabilities.csv contains one row per CVE-product pair. Empty version bounds mean unbounded; a non-empty version_note means the range needs human verification.

Column	Type	Meaning
cve_id	text	CVE-YYYY-NNNNN; stable record key
published_date	ISO date	Publication date from NVD
description	text	Official technical description
cvss_score	0-10	Technical severity; may be empty
vendor	text	Normalised lowercase vendor
product	text	Normalised lowercase product
version_start	text	Inclusive lower bound; empty = unbounded
version_end	text	Inclusive upper bound; empty = unbounded
version_note	text	Warning when a range is not cleanly comparable
in_kev	boolean	True when present in CISA KEV
epss_score	0-1	Estimated 30-day exploitation probability
reference_url	URL	Primary source or vendor reference
source_snapshot_date	ISO date	When the organiser froze the data

profiles.json minimum structure

Field	Meaning
profile_id, name, sector	Identity and display context; sector is not a scoring signal unless evidence supports it
technologies[]	vendor, product and optional version
service	Human-readable business service, such as student portal or appointments
exposure	internet-facing or internal
importance	critical, high or normal

Organiser readiness checklist

- Freeze and test the starter files before kick-off; include a short data dictionary.
- Prepare three public development profiles and one sealed Profile D using the identical schema.
- Seed at least one high-CVSS but irrelevant or unaffected item for the negative test.
- Brief judges on uncertainty handling, provenance spot-checks and the 60-second usability test.
- State the AI policy and internet availability at kick-off; no paid dependency should be required.